

Security Incident Response Plan

Northwind Systems GmbH

Document ID: SEC-IRP-002

Version: 3.4

Effective date: 1 February 2026

Owner: Information Security

Classification: Internal

Review cycle: Semi-annual

Tested: Tabletop exercise, 14 November 2025

1. Purpose and Scope

This plan describes how Northwind Systems detects, reports, contains and recovers from security incidents, and who is responsible at each stage.

It covers any event that compromises, or may compromise, the confidentiality, integrity or availability of company or customer information. It applies to every employee and contractor, not only to technical staff -- most incidents are noticed by somebody who is not in a security role.

Product outages with no security dimension are handled by the service operations runbook, not by this plan. When it is unclear which applies, use this plan; the cost of over-reporting is negligible.

2. What Counts as an Incident

Report any of the following. This list is illustrative, not exhaustive.

- Information reaching someone who should not have it -- a document, an export, a message or an attachment sent to the wrong recipient, shared with the wrong permissions, published to the wrong place, or left where an unauthorised person could read it.
- A device lost or stolen, whether or not it was locked.
- A credential entered into a page that later looked wrong, or a credential found somewhere it should not be.
- An authentication prompt on your account that you did not initiate.
- A message you believe to be phishing, particularly one you interacted with.
- Malware detection, unexpected software, or a device behaving in a way you cannot explain.
- Access to a system you should not have, discovered by accident.
- An access badge lost or stolen.
- A third party informing you that they have suffered a breach affecting our data.
- Any observation that simply feels wrong and that you cannot account for.

3. Reporting: What to Do First

3.1 Report immediately

The moment you suspect that information may have been exposed, disclosed or accessed without authorisation, contact the security team straight away.

Security incident hotline: extension 4911, or +49 89 4911 000 from outside. The hotline is answered by a duty responder twenty-four hours a day, every day of the year.

The hotline is the primary channel because it is the fastest and because it reaches a person rather than a queue. A written report may also be filed at security@northwind.example, and a report affecting a customer-facing service should additionally be raised in the incident channel -- but the call comes first and is not delayed while a written report is composed.

Report even when you are not certain. Report even when the exposure appears trivial. Report even when it was you who caused it.

3.2 Do not investigate or fix it yourself

Do not attempt to establish the extent of the exposure, and do not attempt to contain or remediate it on your own.

This is not a matter of trust. Well-intentioned independent action routinely makes an incident worse:

- Deleting the message, the file or the export destroys the evidence needed to establish what was actually exposed and to whom, and the deletion itself is frequently irreversible.
- Logging into the affected system to "have a look" overwrites access logs, mixes your activity into the timeline, and can alert an attacker who is still present.
- Rebooting, reimaging or running a cleanup tool on a compromised device destroys volatile memory that would have identified what happened.
- Contacting the unintended recipient before the response team has assessed the situation can escalate a recoverable mistake into a formal complaint or a regulatory matter.
- Changing credentials before the team is ready can tip off an attacker while their other footholds are still open.

Your role is to report accurately and quickly, then to follow the duty responder's instructions.

3.3 What to preserve

Leave everything as it is. Do not delete, do not tidy, do not close the application. If a device is suspected of compromise, disconnect it from the network -- unplug the cable or disable the wireless adapter -- but leave it powered on, and wait for instructions.

Note down the time you noticed, what you observed, and what you had done immediately beforehand. This note is often the most valuable single artefact in the investigation.

3.4 Reporting in good faith is never penalised

No disciplinary consequence follows from reporting an incident in good faith, including one the reporter caused. Concealing an incident, or delaying its report, is itself a serious matter. Early reporting is consistently the largest single factor in how much damage an incident does.

4. Severity Classification

The duty responder assigns a severity within thirty minutes of the report.

- **SEV1 -- Critical.** Confirmed unauthorised access to customer personal data, to production systems, or to Restricted information. Ransomware. Any incident with a probable regulatory notification obligation. Executive leadership informed immediately.
- **SEV2 -- High.** Confirmed exposure of Confidential information with limited scope. Compromise of a single account or endpoint. Significant control failure with no confirmed exposure yet.
- **SEV3 -- Moderate.** Suspected exposure not yet confirmed. Isolated policy breach with contained impact. Phishing that was interacted with but where no credential was entered.
- **SEV4 -- Low.** Reported phishing with no interaction. Near miss. Minor control weakness observed.

Severity is provisional and is revised as facts arrive. It is deliberately assigned pessimistically at the outset.

5. Roles

- **Incident commander** -- Runs the response, makes containment decisions, owns the timeline. A member of Information Security for SEV1 and SEV2. The commander directs; they do not perform the technical work themselves.
- **Duty responder** -- Answers the hotline, performs triage, assigns provisional severity, escalates.
- **Technical lead** -- Directs investigation and containment on the affected systems, nominated from the owning team.
- **Communications lead** -- Owns all internal and external messaging. Nominated for SEV1 and SEV2.
- **Legal and data protection** -- Assesses notification obligations. Engaged for every incident involving personal data, without exception.
- **Scribe** -- Maintains the contemporaneous log of decisions, times and actions.

6. Response Stages

1. **Detect and report** -- Section 3.
2. **Triage** -- The duty responder establishes what is known, assigns provisional severity, and appoints the incident commander.
3. **Contain** -- Stop the exposure spreading: isolate devices, disable accounts, revoke tokens and sessions, block addresses, disable the affected feature. Containment takes priority over diagnosis.
4. **Investigate** -- Establish scope: what was affected, over what period, by whom, and what left the perimeter. Preserve evidence throughout.
5. **Eradicate and recover** -- Remove the cause, rebuild rather than clean where compromise is suspected, rotate every credential in scope, restore service and verify it.
6. **Notify** -- Section 7.
7. **Review** -- Section 8.

7. Notification

Legal and data protection assess the notification obligation for every incident involving personal data. Where a notifiable personal data breach is confirmed, the supervisory authority must be notified within seventy-two hours of the company becoming aware of it, which is why the clock starts at the first report and not at the point the investigation concludes.

Affected individuals are notified where the breach is likely to result in a high risk to their rights and freedoms. Affected customers are notified in line with the terms of their contract.

All external communication is issued by the communications lead. No other employee comments on an incident to a customer, a partner, the press or on social media, and questions received are passed to the communications lead unanswered.

8. Post-Incident Review

A written review is held within five business days of closure for SEV1 and SEV2, and within ten for SEV3.

The review is blameless. It establishes the sequence of events, why the situation made sense to the people involved at the time, what detected it, what delayed the response, and what specific changes will be made -- each with a named owner and a date.

Actions are tracked to completion by Information Security and reported to the Executive Board quarterly. A review that produces only a training action is treated as incomplete.

9. Testing

The plan is exercised twice a year: one tabletop exercise covering a scenario chosen by Information Security, and one technical exercise covering detection and containment. Findings are treated as post-incident review actions.

10. Contact Summary

- Security incident hotline: extension 4911, or +49 89 4911 000
- Written report: security@northwind.example
- IT service desk (non-security faults): extension 4400
- Facilities, including physical security: extension 4100

11. Related Documents

- Information security policy
- Data retention schedule
- IT service desk handbook
- Software release and change management process